Mosaic

Future Plan & Pilot Plan
Cross-release mosaic defence for the TrustED PETs proving ground

---

Approach. We attack first. Measure the linkage join on unprotected releases, lock the baseline, protect with per-release HMAC tokens, then re-attack until the same join is 0/0 under a hard mosaic gate.

1. Where we are today

The MVP path (P0–P7) is built: OPS-1 pack integrity, Attack A baseline (HETU **1622** / phone **1484**), protect for HEALTH-S1 and FIN-S2, re-attack, mosaic gate (PASS-1 zeros + PASS-2 baseline lock), scorecards, analyze HTML, and a narrated demo. Optional Groq agents (P8 A2) advise in shadow mode only — they never write `clean_data/` or flip a release PASS.

2. Future plan

The roadmap keeps the same loop — measure → derive requirement → protect → re-attack → gate — and widens scope without forking the architecture.

2.1 Near term (product)

- **Widen scenarios.** Next pair: ENERGY-S3 × CS-S1 (widest phone glue; medical_device_priority payload). Always measure the raw baseline before protecting.
- **Restore FIN utility.** Include withheld `cards` / `card_transactions` under FIN-S2 so pets-eval utility and composite are meaningful (today they can be 0 while mosaic still PASSes).
- **Agent graduation (P8 A3→A4).** Shadow free-text helpers (`redact_assist` / `discover_assist`), then advisory pre-test that can delay a release but never auto-PASS. Start on HEALTH `chief_complaint`.
- **Gated apply path.** Human accept/reject of agent proposals recorded; deterministic gate remains the only PASS authority.

2.2 Medium term (platform)

- Multi-release mosaic matrix: any two outward scenarios that share glue types, with per-pair baselines and PASS-2 locks.
- Key rotation / recipient revocation runbook without rewriting historical releases incorrectly.
- Hardening free-text glue (notes, turns) once CS/energy enter scope — residual risk R-text outside the two-file MVP.
- CI packaging: one-command release evidence pack (gate JSON, scorecards, analyze HTML, OPS-1 verify) for auditors.

2.3 Longer term (adoption)

- Controller playbook: how a real data controller runs attack-first protect before shipping extracts to research / processor recipients.
- Policy alignment: document HMAC domains vs GDPR Art. 9 / processor contracts when live LLMs touch free text.
- Beyond proving-ground CSVs: connector adapters that preserve string dtypes and the same phone/HETU/IBAN normalisation recipe (R2).

3. Pilot plan

A short, gated pilot with one data owner (or TrustED lab host) to prove attack-first defence on real release workflow — not a rewrite of Mosaic.

3.1 Goals & non-goals

- **Goals:** reproduce Attack A on agreed extracts; protect two recipient releases; show 0/0 re-join; deliver gate + scorecard + analyze evidence; optional agent brief for reviewers.

- **Non-goals:** editing vendored pack inputs; auto-applying LLM proposals; claiming official pets-eval judging; shipping keys or raw glue off-site.

3.2 Phases (6–8 weeks)

Phase	Weeks	Activities	Exit criteria
0 — Align	1	Pick release pair & recipients; threat story; success metrics; data-handling rules (AR-4).	Signed scope note; OPS-1 / input integrity agreed.
1 — Attack	1–2	Ingest extracts; run Attack A; lock baseline join counts; positive control on known overlap.	Baseline numbers recorded; PASS-2 recipe fixed.
2 — Defend	2–3	Protect with per-release HMAC; drop vs tokenise decisions; re-attack; mosaic_check + scorecards.	PASS-1 = 0/0; PASS-2 matches Phase 1; verdict PASS.
3 — Review	1	Analyze HTML + optional Groq advisory brief; human accept/reject log; demo to stakeholders.	Evidence pack archived; go / no-go for wider rollout.
4 — Next	1	Pilot retrospective; backlog (new pair / FIN tables / A3 text); draft controller playbook.	Written next-phase plan with owners.

3.3 Roles & success metrics

- **Roles:** Pilot lead (scope), Mosaic engineer (pipeline/gate), data steward (keys + extracts), reviewer (accept/reject proposals).
- **Must-pass:** raw join measurable; protected join 0 on agreed keys; OPS-1 / integrity verify; no raw HETU/phone/IBAN/email in agent egress.
- **Target:** stakeholder can explain attack-first in one slide; evidence pack reusable without retuning baselines.

3.4 Risks & mitigations

Risk	Mitigation
Scope creep into many datasets	One pair only; measure-first rule before any new table.
Utility looks ‘broken’ (FIN composite 0)	Separate mosaic PASS from pets-eval utility; document withheld tables.
LLM leaks identifiers	AR-4 contracts; agents advisory; kill-switch to deterministic path.
Baseline drift / tampered inputs	OPS-1 SHA-256 verify before and after runs.

4. Immediate next actions

- Confirm pilot host, release pair, and calendar (Phase 0).
- Freeze demo evidence from current HEALTH-S1 × FIN-S2 PASS as the reference pack.
- Open backlog tickets: ENERGY×CS measure-first; FIN cards inclusion; P8 A3 shadow on `chief_complaint`.